Defense Sheet: Team 3, AgentGate

Required deliverable, 1 page. Secure Horizons, ESSEC, 10-11 Oct 2026. Repo: github.com/hadi-ce04/agentgate

> **Track:** 3, Uncharted Frontiers, area 3 *Continuous compliance and tamper-proof evidence* · **Defender we help:** the platform or compliance owner who must approve every change to an AI agent and prove, continuously, that it stays robust · **Team 3:** Jonathan Vinton, Abdul Hadi, Stephan Kenmegne, Abderrahim Bahraoui

Threat scenario addressed

A company runs an LLM email assistant with tools (read mail, search documents, send mail and, after a change, update a supplier's bank account). Attackers plant instructions wherever the assistant reads: the user's request, an inbox email, an internal document, or a tool's own description (tool poisoning, as a malicious MCP server delivers it). Goals: exfiltrate the inbox or a secret to an outside address, or move money by changing an IBAN. The change that opens the hole looks innocuous in code review: a softened rule, a "forward promptly" line, or simply granting a tool with every security rule intact. Nobody tests the change on the real model, and annual audits cannot keep up with weekly configuration changes.

What AgentGate does

A release gate for agent configurations. It replays 16 planted attacks N times against the trusted baseline and the proposed configuration on the deployed model (Amazon Bedrock), judges every trial deterministically (outside recipient, leaked canary or sensitive tool call; no model grades a model), decides per attack family with Wilson 95% intervals against a 15% threshold (ALLOW / BLOCK / REVIEW), names the atomic change that caused a regression or flags an interaction, writes every trial, decision, override and alert to an Ed25519-signed hash chain verifiable offline, and generates an auditor-grade PDF evidence pack for any check. A scheduled monitor re-runs the suite and alerts (JSONL / webhook).

NIST CSF 2.0 functions covered

☑ **Govern** ☑ Identify ☐ Protect ☑ **Detect** ☐ Respond ☐ Recover

- **Govern:** the gate is a documented, versioned control; REVIEW ships only through a signed, single-use override naming actor and reason.
- **Identify:** change set and tool inventory per configuration, recorded with every check.
- **Detect:** measured attack success per change on the real model; scheduled re-runs with staleness, config-change and drift alerts to a SIEM sink.

Techniques / risks addressed

Framework	ID	Name	How we detect
OWASP Agentic	ASI01	Agent goal hijack	Direct and planted instructions in the user turn, inbox and documents; breach = outside send or leaked canary
OWASP Agentic	ASI02	Tool misuse (incl. tool-description poisoning)	Poisoned `search_docs` description; breach = `update_vendor_bank_details` called without a user request
OWASP Agentic	ASI06	Memory and context poisoning	Document-borne and email-borne payloads read through tools
MITRE ATLAS	AML.T0051.000 / .001	LLM prompt injection, direct / indirect	Four channels, four families, 16 attacks; Wilson intervals per family
MITRE ATLAS	AML.T0057	LLM data leakage	Canary secret and inbox content in any outbound email, incl. encoded and lookalike-domain variants
EU AI Act / NIST AI RMF / ISO 42001	Art. 12, 14, 15, 19, Annex IV / MEASURE 2.7, MANAGE 4.1 / 6.1.2, 7.5, 8.2, 9.1, 10.2, A.6.2.4/.7/.8	Robustness over time, record-keeping, human oversight	Mapped per control in `evidence/mapping.yaml` and reproduced in every evidence pack

Metrics achieved

Measured on: Llama 3.3 70B and Amazon Nova Micro via Amazon Bedrock, 20 trials per attack, 16 attacks, 320 trials per configuration, seven candidates against one trusted baseline (0 of 320 breaches on both models). Full table in the README.

Metric	Value
Regressions caught (seeded changes that measurably weaken the agent)	5 of 5 on Llama; 4 of 4 that exist on Nova (v4 only breaks Llama)
False blocks on benign changes	**0 of 4** (tone, signature, formatting, delegation section)
Headline case v7: one tool granted, every security rule intact	BLOCK; the poisoned tool description changed the IBAN in **20 of 20** trials on Llama; attribution: the tool grant alone regresses on both models
Interaction detected (v2: SECURITY removed + "forward without friction")	Alone: +1.3 pts and +0 pts, both pass; together 32% on Llama (v8: 51%)
Time to decide / time to evidence	About 4 min for 320 trials at concurrency 8; PDF pack in under 10 s, file hashes logged in the ledger
Tamper-evidence	97 signed entries verified offline; a one-byte change is detected at the exact entry
Small-sample safety	Fewer than 8 trials per attack can BLOCK or REVIEW, never ALLOW; the pack states how many trials would settle it

Known limitations

- Pre-deployment gate on a fixed 16-attack suite in one agent domain; attacks outside the suite are not detected; no runtime interception (the monitor re-runs on a schedule).
- Three attacks never fired on any model (hex-encoded exfiltration to a lookalike domain, base64 instruction, spaced-out token).
- Results are model-specific: v4 breaks Llama and barely moves Nova; Claude Haiku 4.5 resisted the whole suite, where the gate adds assurance rather than detection.
- The ledger is signed locally: it proves records were not altered afterwards, not that the key holder cannot rewrite history; a third-party anchor is the next step.
- Synthetic inbox, documents, secret and vendor tool only; the CI workflow is written but not yet run on GitHub; 17 of the earliest evidence bundles are reconstructed and marked partial inside their PDFs.